DISCLAIMER — EDUCATIONAL & ETHICAL PURPOSES ONLY

• This presentation, workshop, code, demonstrations, case studies, examples and entire contents are provided solely for educational, training, experimentation, and ethical learning purposes only.

• The lab is intentionally simplified and is not a production-ready banking application, security framework, compliance solution, or financial system.

• Use synthetic/sample data only. Do not connect the lab to real customer data, credentials, production systems, or live financial transactions without appropriate review.

• Prompt-injection, red-team, authorization, and security-testing activities must be performed only against systems and environments for which you have explicit authorization.

• Developers and organizations are responsible for independently validating, strengthening, testing, and adapting the patterns to their own use case, architecture, security standards, regulatory obligations, privacy requirements, and organizational policies.

• The Presenters and The Hosts do not assume any responsibility or liability for consequences arising from the use, misuse, modification, deployment, or adaptation of these educational materials, to the extent permitted by any applicable law.

Google Developer Groups
New Delhi

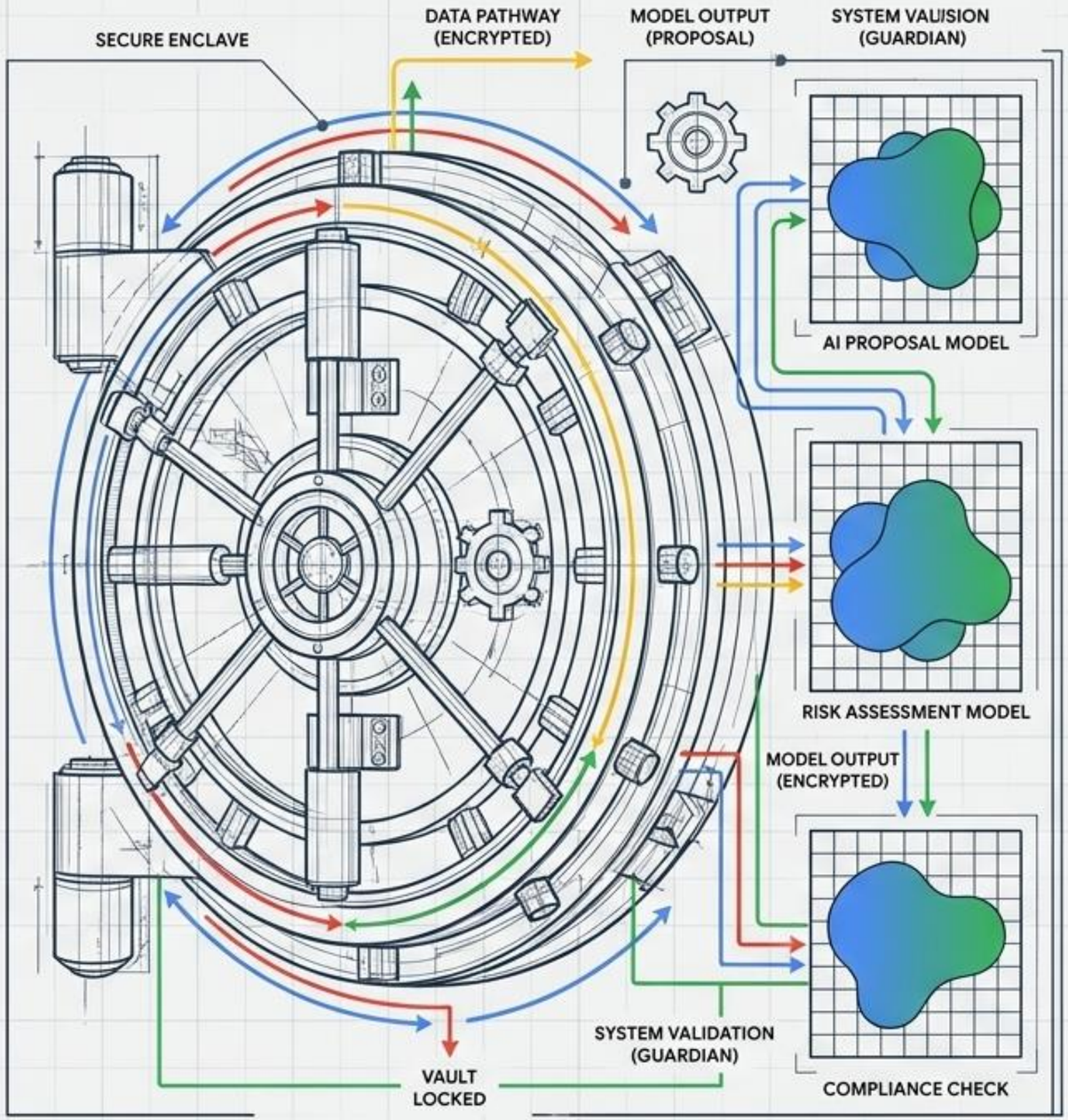
DevFest
नई दिल्ली 2026

Safe by Design: Building Guardrails for AI in Banking

The model proposes. The system decides.



Ankit Mathur
AVP, NatWest Group



Gemini Notebook

LinkedIn Profile



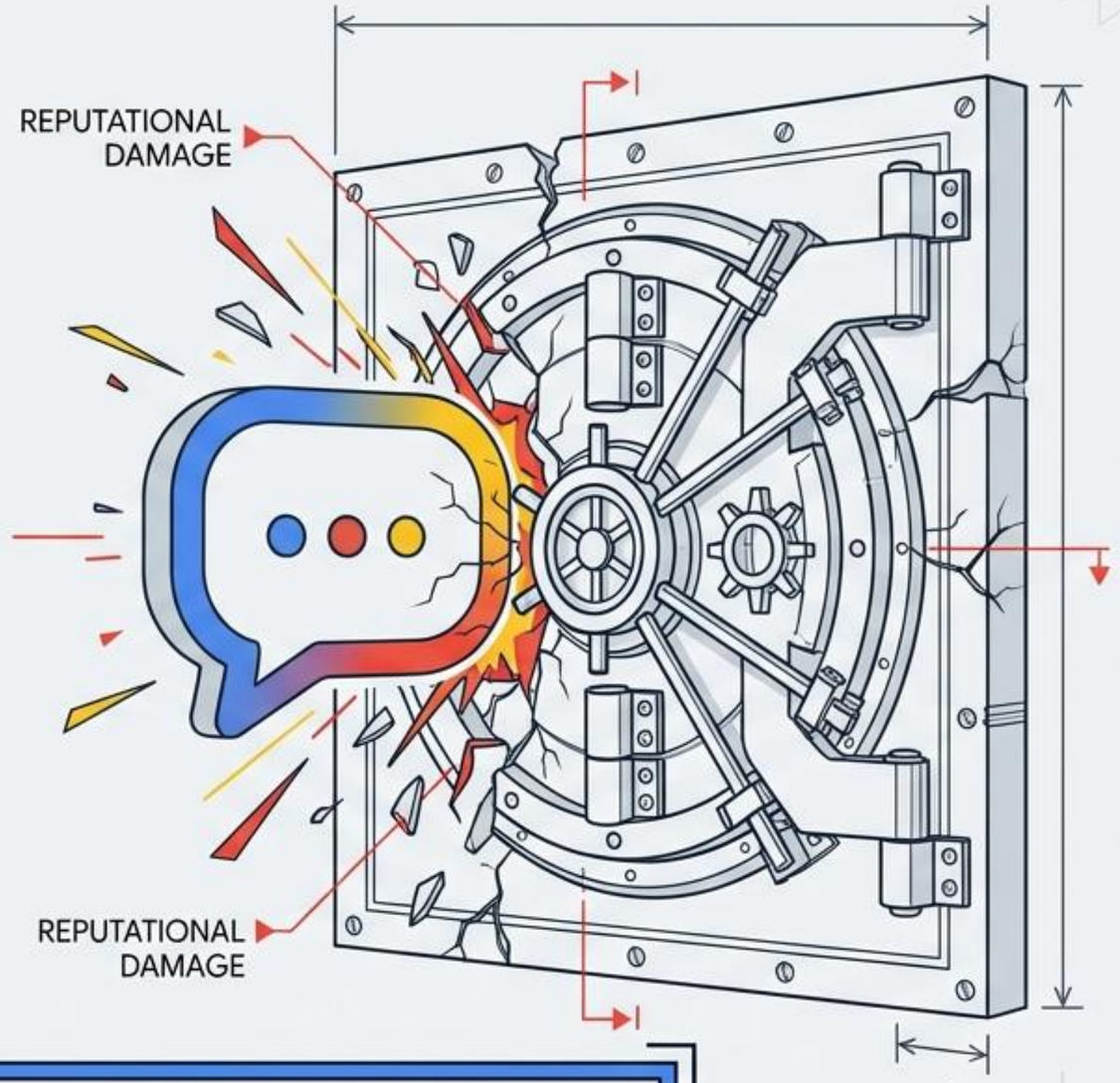
The Catastrophic Cost of Unguarded AI

INCIDENT: Moffatt v. Air Canada (2024)

RULING: Courts treat a chatbot's words as the company's words.

RISK: A confident but incorrect statement about a fee, rate, or policy is a severe conduct risk.

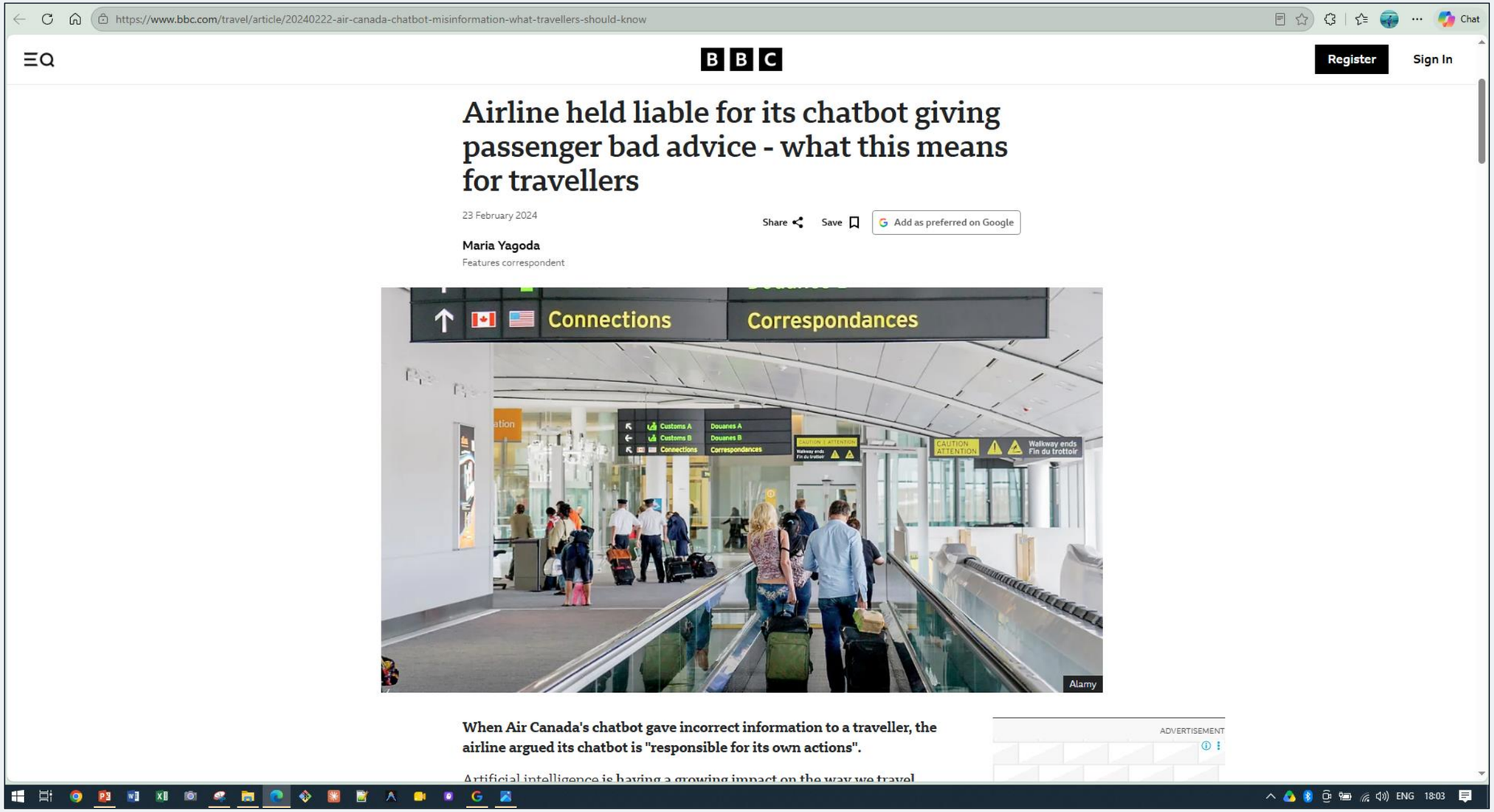
ESCALATION: Missing guardrails rapidly escalate from bad output to regulatory and reputational crises.



TAKEAWAY: In regulated environments, an **output filter alone** cannot stop an autonomous agent from taking the **wrong action**.

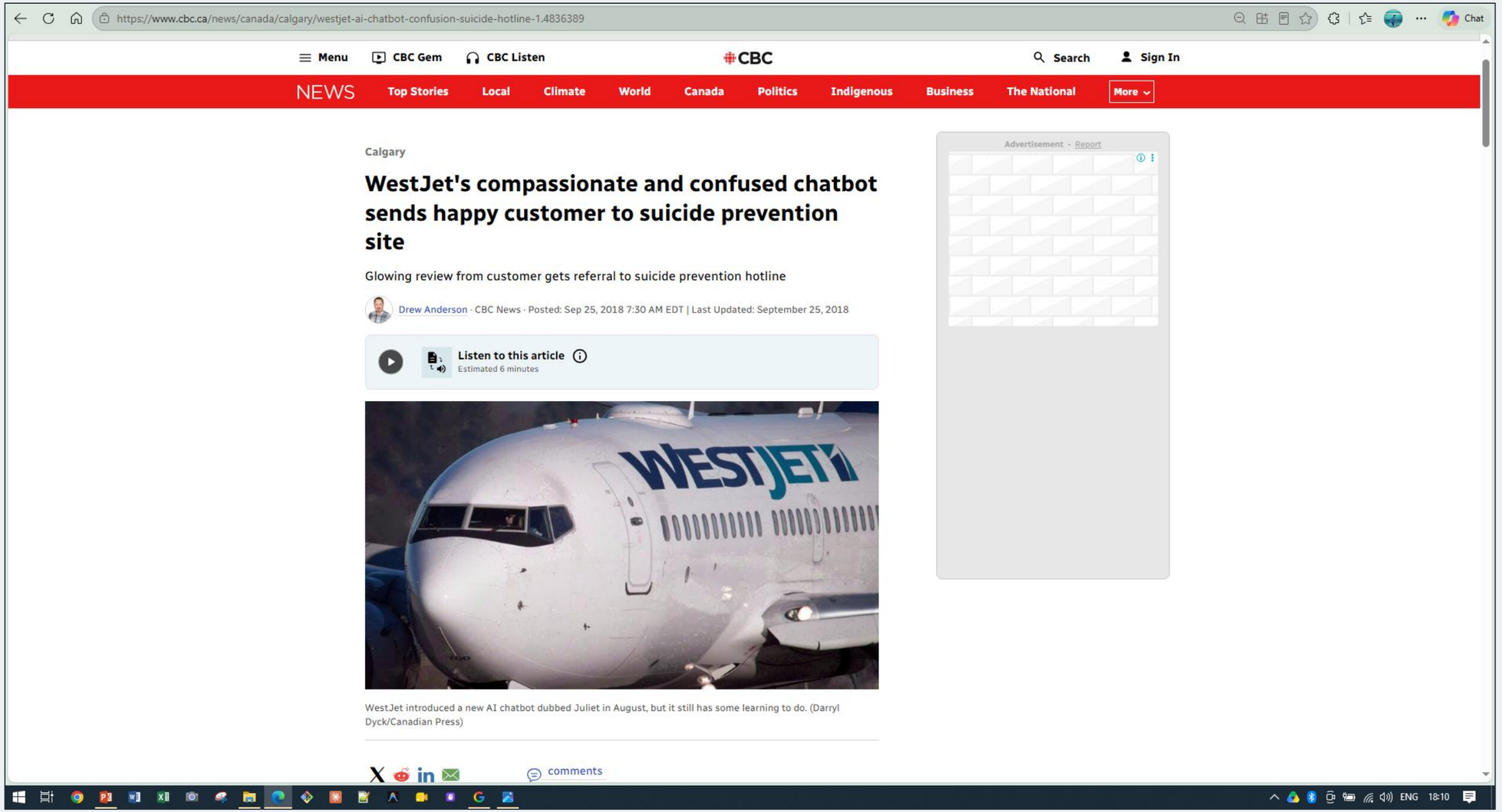
Public References:

1. https://www.bbc.com/travel/article/20240222-air-canada-chatbot-misinformation-what-travellers-should-know
2. https://www.americanbar.org/groups/business_law/resources/business-law-today/2024-february/bc-tribunal-confirms-companies-remain-liable-information-provided-ai-chatbot/



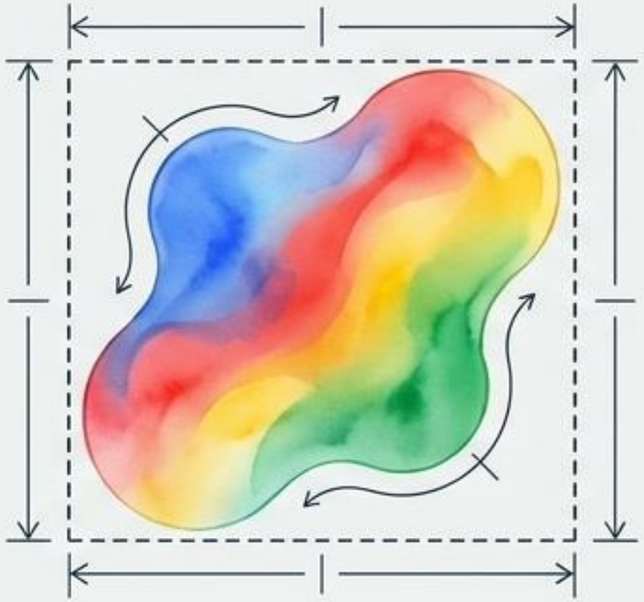
Public References:

1. https://www.cbc.ca/news/canada/calgary/westjet-ai-chatbot-confusion-suicide-hotline-1.4836389



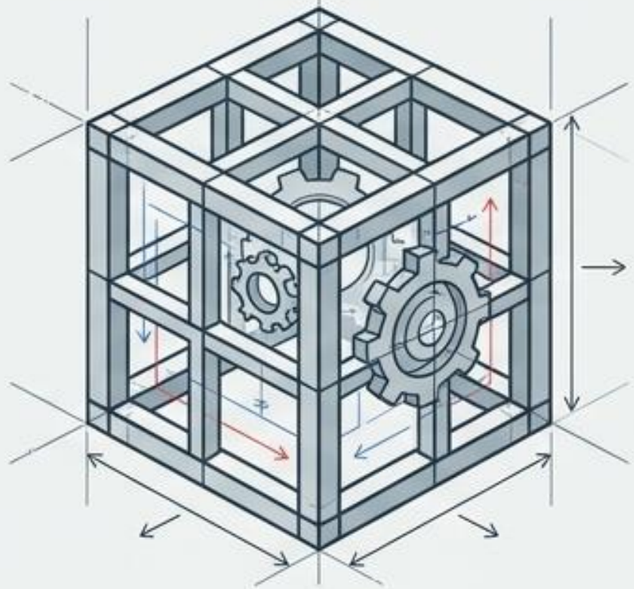
The Core Conflict: Probabilistic Models in Deterministic Worlds

The Model (AI)



- Probabilistic output.
- Generates text and influences decisions.
- Can be useful, wrong, manipulated, or overconfident.

The Bank (Application)

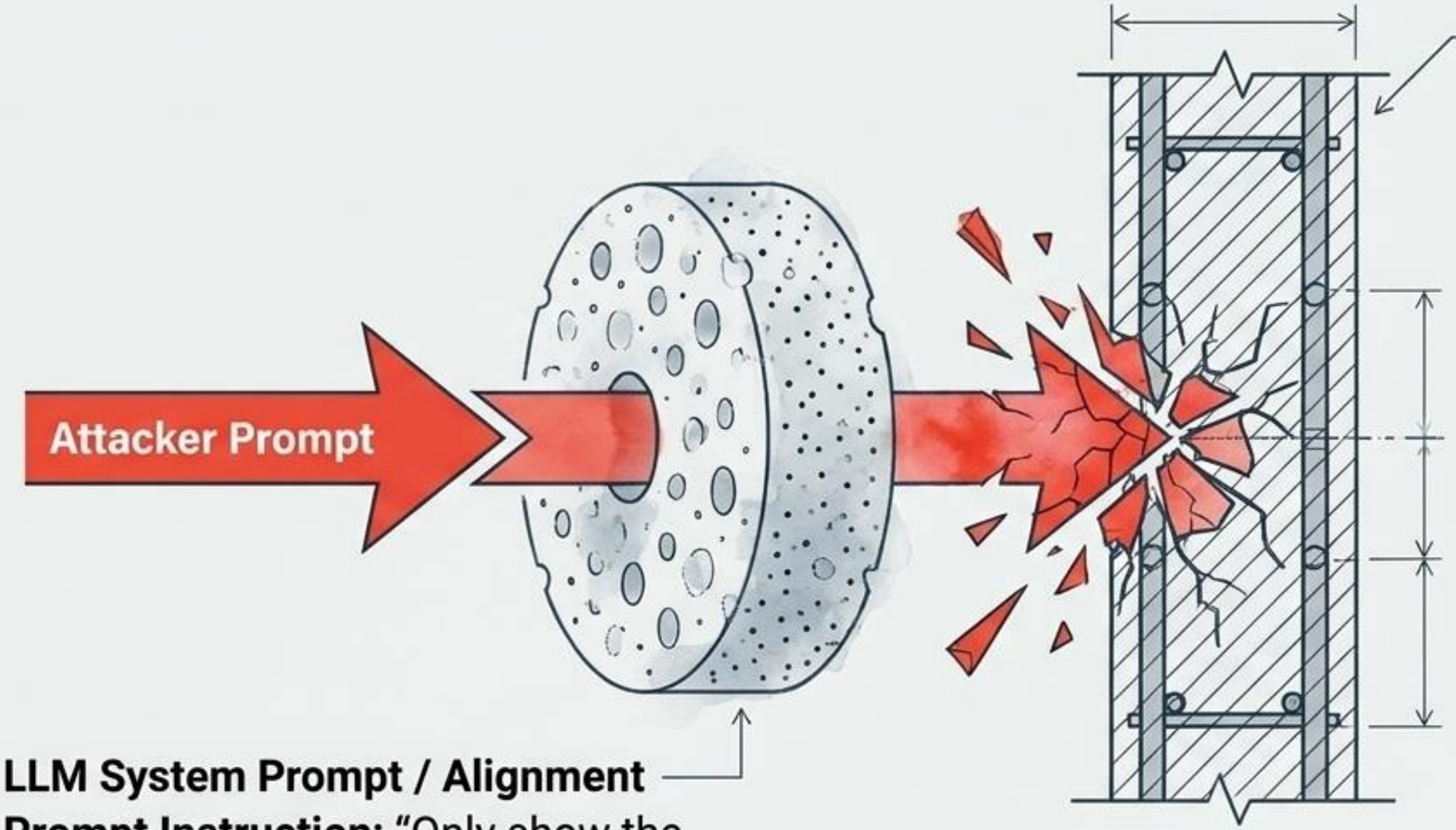


- Deterministic consequences.
- Manages real data, identity, context, and money.
- Requires absolute policy enforcement.

TAKEAWAY: AI is shifting from answering questions to executing actions. When AI triggers an action, guardrails must become rigid architecture.

Gemini Notebook

A Prompt is Not an Authorization Boundary



Code/Policy Authorization Boundary

Authorization Control: Identity + Resource Ownership + Tool Permission. (Deterministic decision outside the model).

LLM System Prompt / Alignment

Prompt Instruction: “Only show the current user’s transactions.” (Useful guidance, porous boundary).

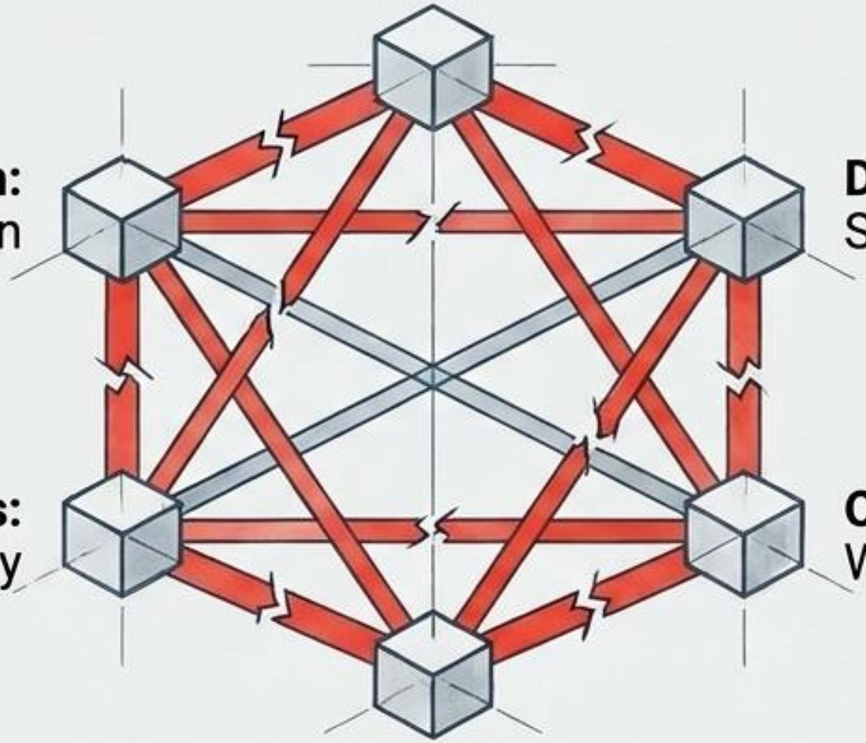
TAKEAWAY: Use the LLM for language. Use hard code and established policies for permission.

Gemini Notebook

The Anatomy of AI Failure Modes

Input:
Prompt Injection

Action:
Unauthorized Execution



Data:
Sensitive Data Exposure

Tools:
Excessive Agency

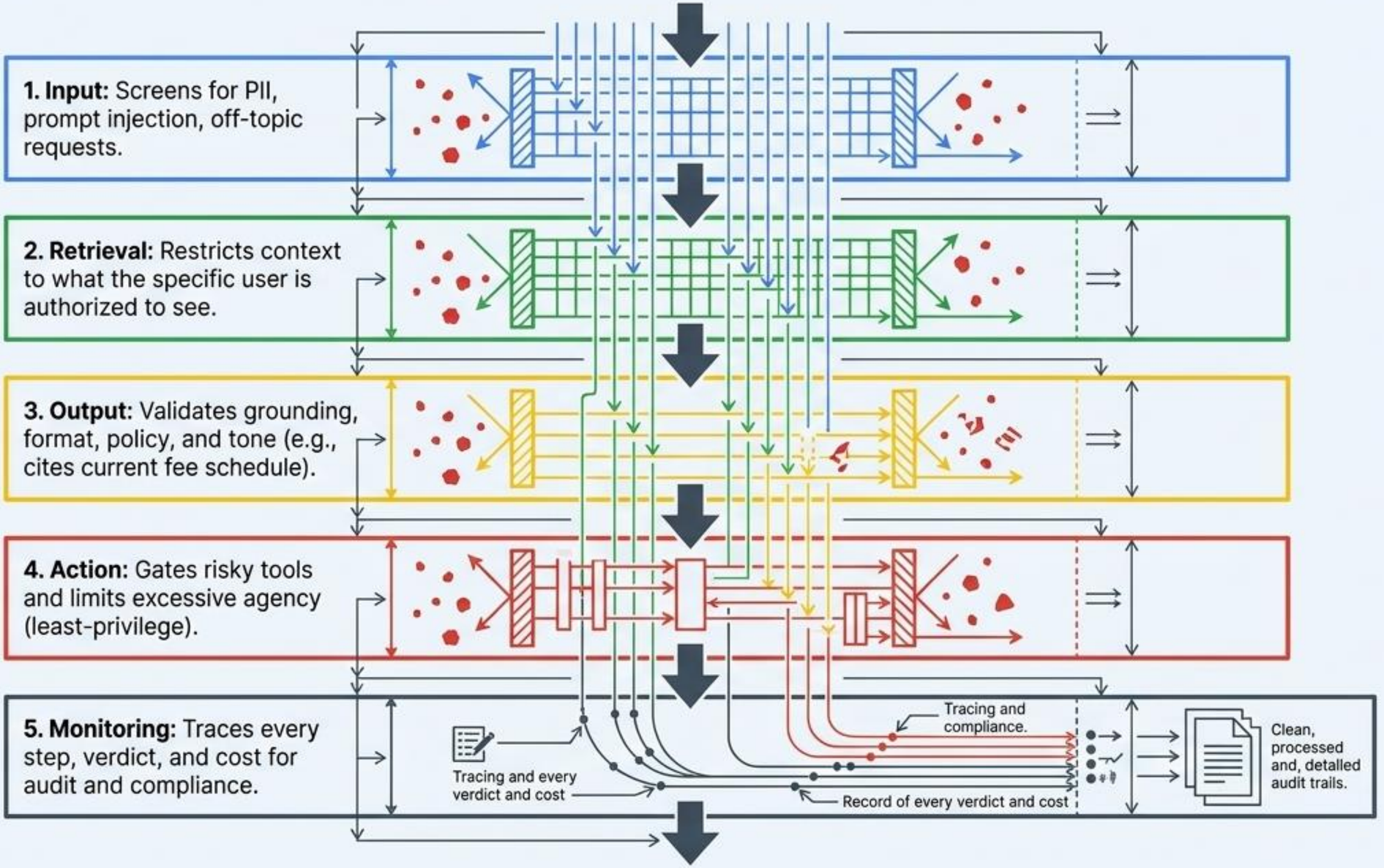
Output:
Wrong Advice / Hallucination

Identity: Unauthorized Access

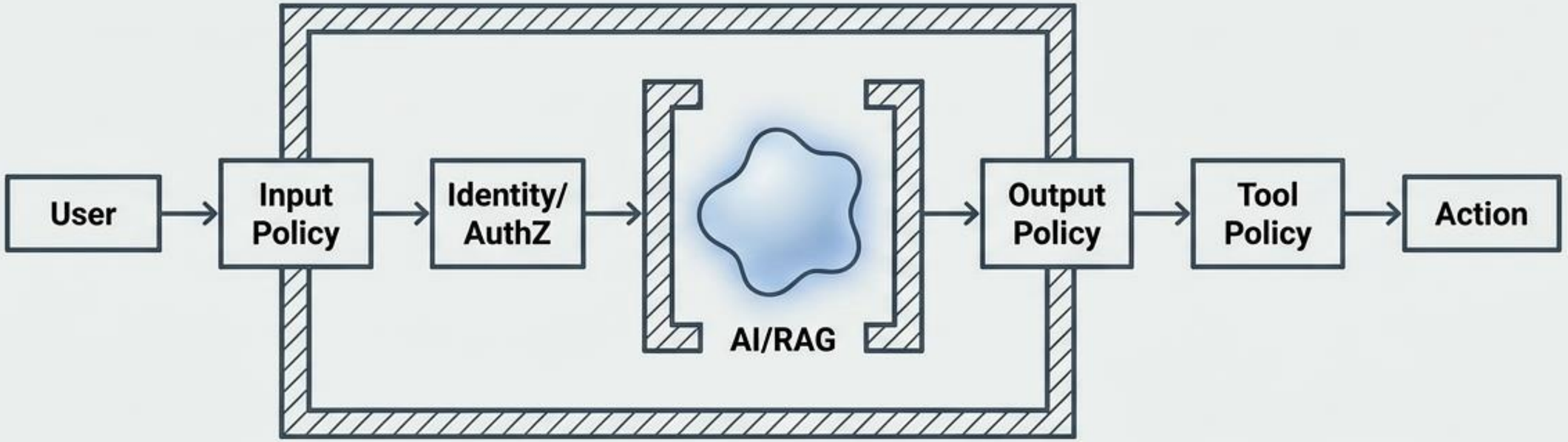
TAKEAWAY: Risk is generated at the intersections between people, models, data, tools, and actions.

Gemini Notebook

The 5-Layer AI Security Stack



The Architectural Blueprint: Enclosing the Model



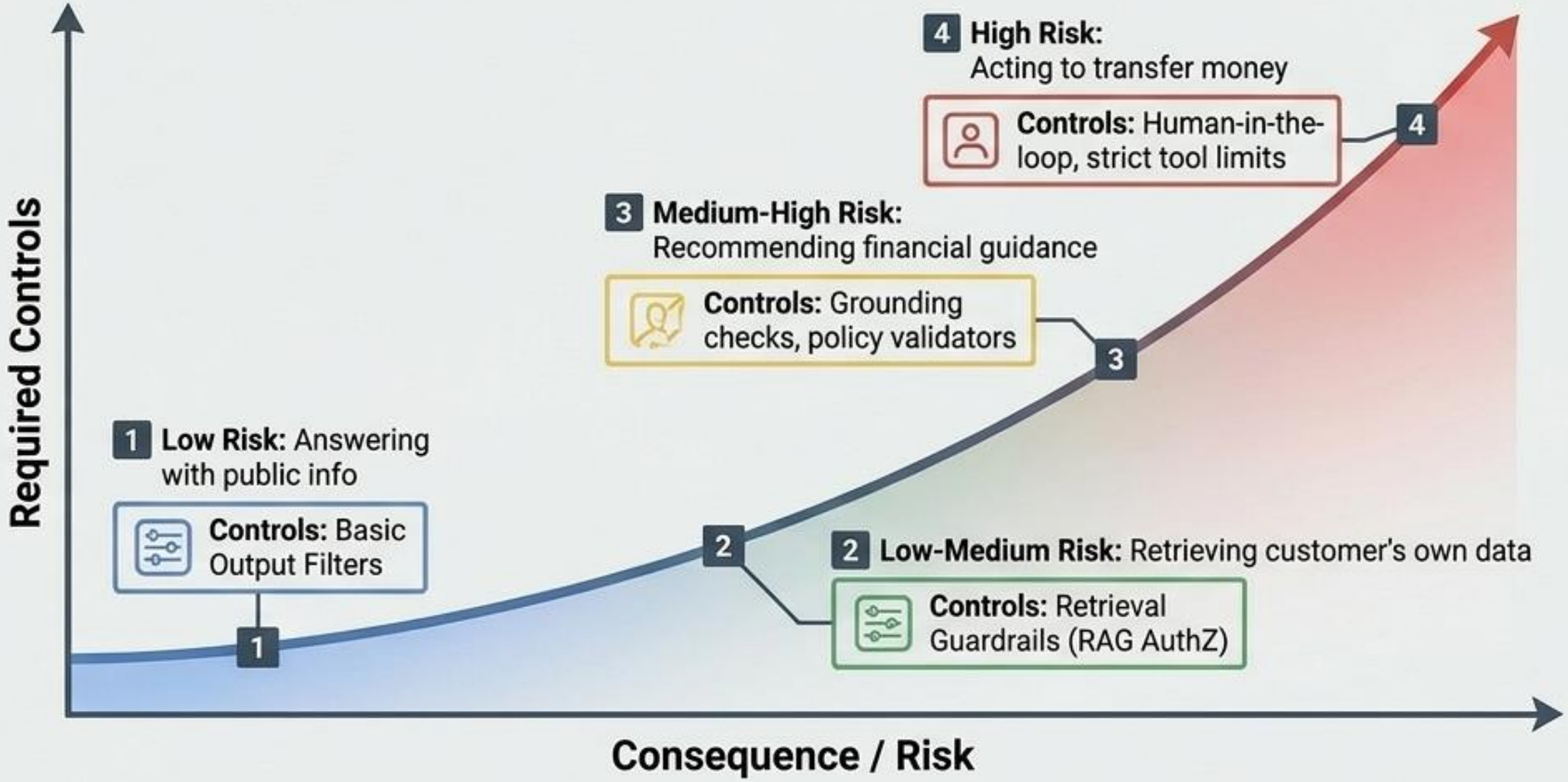
Allow: Low-risk, fully authorized paths.

Block: Immediate termination upon policy violation.

Escalate: High-impact or uncertain actions routed to a human.

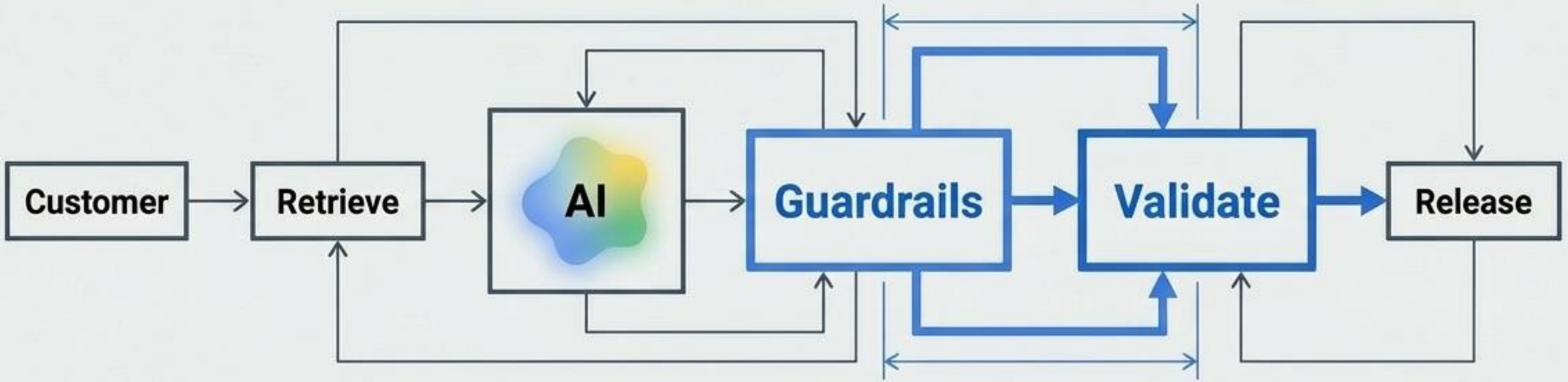
TAKEAWAY: The model proposes an action. The surrounding application code decides whether it is allowed.

Design for Consequence: Match Autonomy to Risk



TAKEAWAY: Higher consequences demand stronger deterministic controls and human oversight.

Case Study: ING — Guarding the Customer Interaction

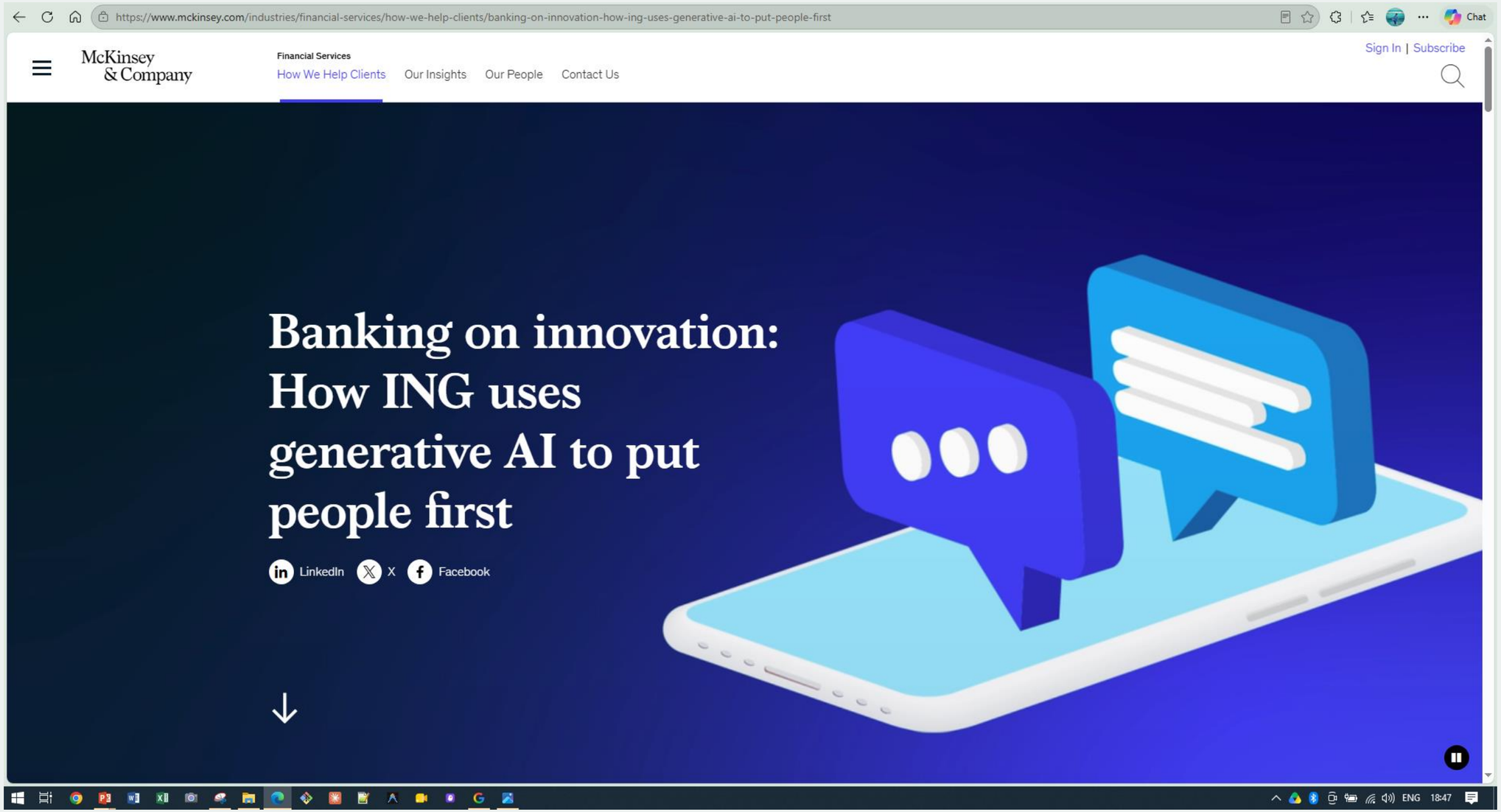


Scale	Build	Controls
85,000 customer interactions/week in the Netherlands.	GenAI chatbot built in 7 weeks (ING + McKinsey). Classic bot only resolved ~40-45%.	Risk stakeholders involved from Day 1. Specific rules implemented for risky advice (mortgages, investments).

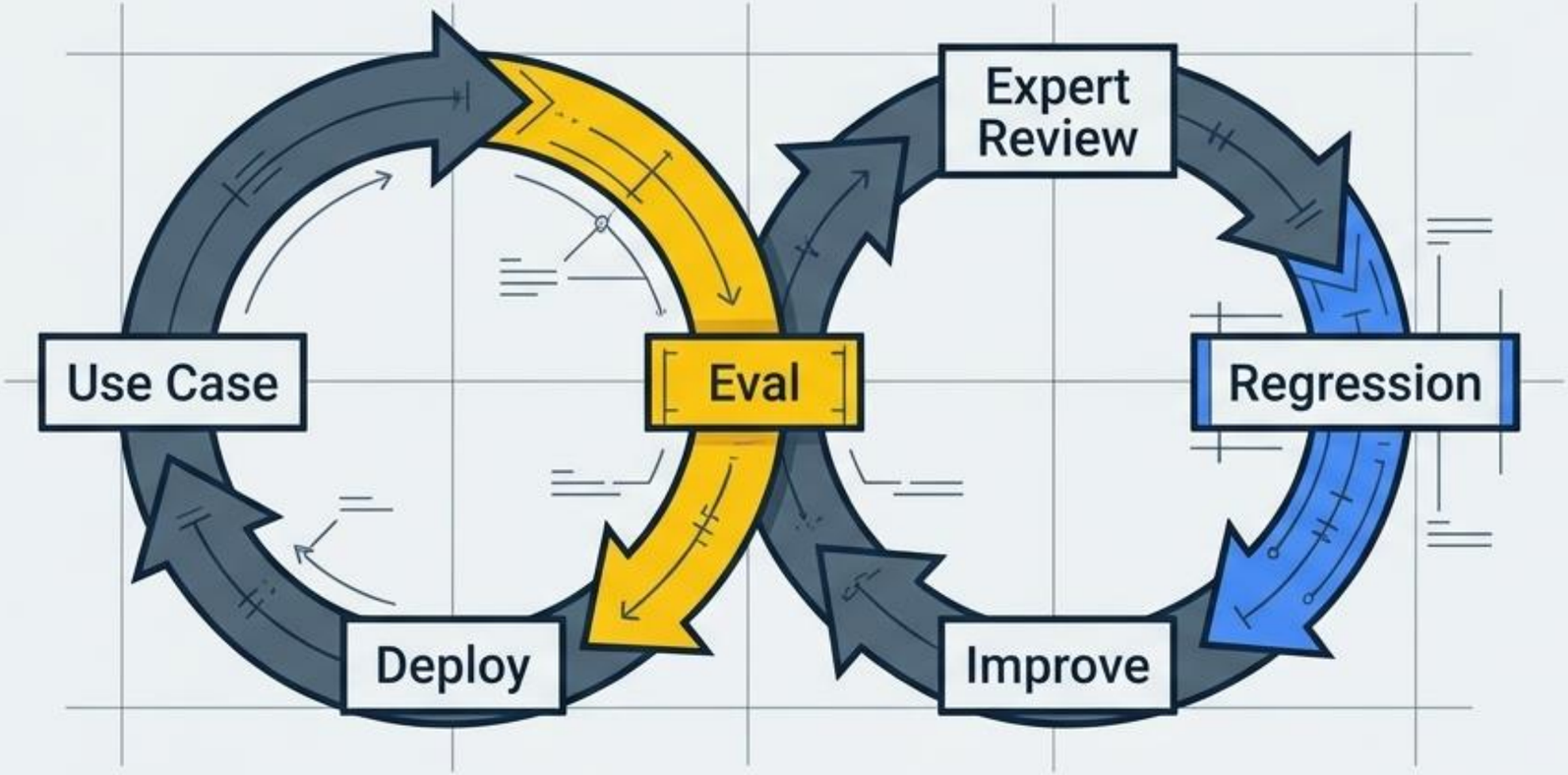
TAKEAWAY: Customer-facing AI requires robust validation controls before the answer leaves the system.

Public References:

1. https://www.mckinsey.com/industries/financial-services/how-we-help-clients/banking-on-innovation-how-ing-uses-generative-ai-to-put-people-first
2. https://www.youtube.com/watch?v=KPSLPKOtD5Y



Case Study: Morgan Stanley — Proving the System Works

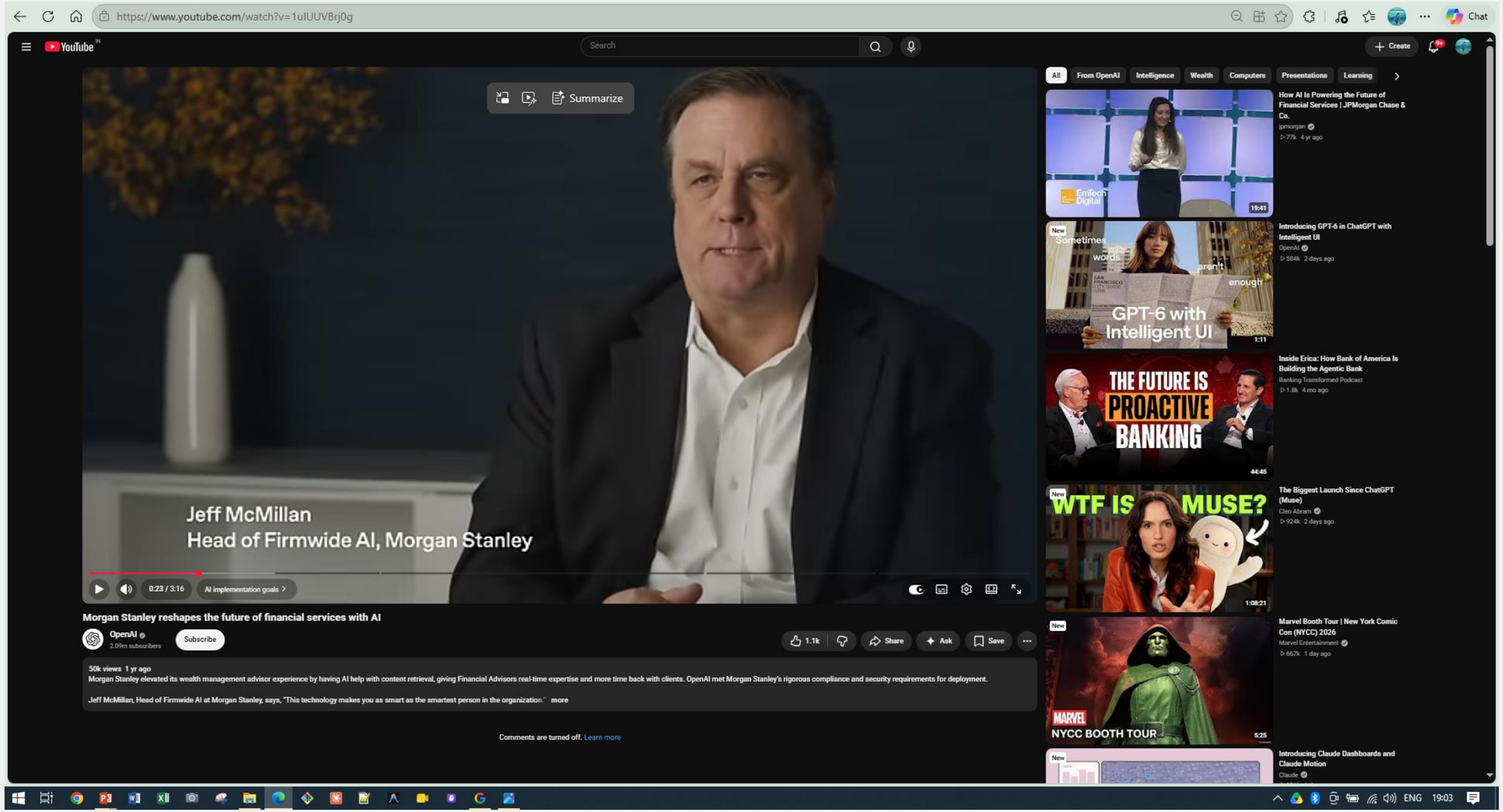


- **Use Case:** AI Assistant helping advisors navigate a massive internal knowledge corpus.
- **Evaluation:** Evals turn “trust” into a measurable, discussable metric. Compared against an expert baseline.
- **Scale & Trust:** Daily regression testing catches breakage immediately. Achieved >98% adoption among advisor teams.

TAKEAWAY: You cannot trust what you cannot test. Continuous evaluation is the engine of adoption.

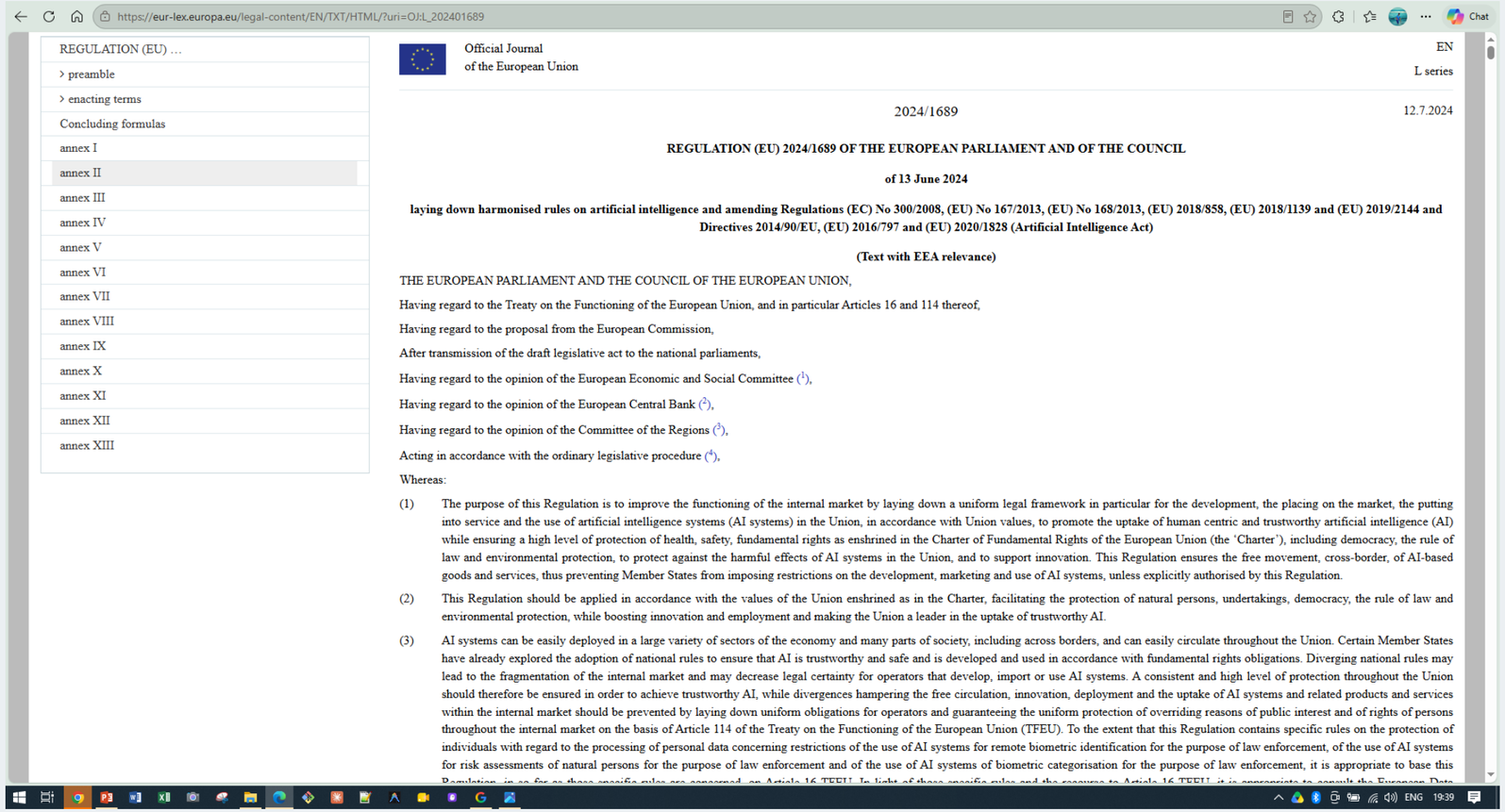
Public References:

1. https://openai.com/index/morgan-stanley/
2. https://www.youtube.com/watch?v=1uIUUVBrj0g



Global Publicly Available Laws , Guidance, and Case Study References

https://www.canlii.org/en/bc/bccrt/doc/2024/2024bccrt149/2024bccrt149.html
https://www.morganstanley.com/press-releases/key-milestone-in-innovation-journey-with-openai
https://www.mckinsey.com/industries/financial-services/how-we-help-clients/banking-on-innovation-how-ing-uses-generative-ai-to-put-people-first
https://www.consumerfinance.gov/data-research/research-reports/chatbots-in-consumer-finance/
https://search.ftc.gov/legal-library/browse/cases-proceedings/2023190-rite-aid-corporation-ftc-v
https://www.bbc.com/news/technology-68025677
https://www.fsb.org/2024/11/the-financial-stability-implications-of-artificial-intelligence/
https://www.mas.gov.sg/schemes-and-initiatives/project-mindforge
https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/
https://www.nist.gov/itl/ai-risk-management-framework
https://eur-lex.europa.eu/eli/reg/2024/1689/oj
https://www.bbc.com/news/technology-68025677



The ROI of Architecture: What Do Guardrails Save?

Assumptions	100,000 interactions/month. 15% sent to human review ($3/review).
Impact	Guardrails reduce avoidable reviews by 7 percentage points.

7,000 fewer reviews/month × $3

= **$21,000** saved/month

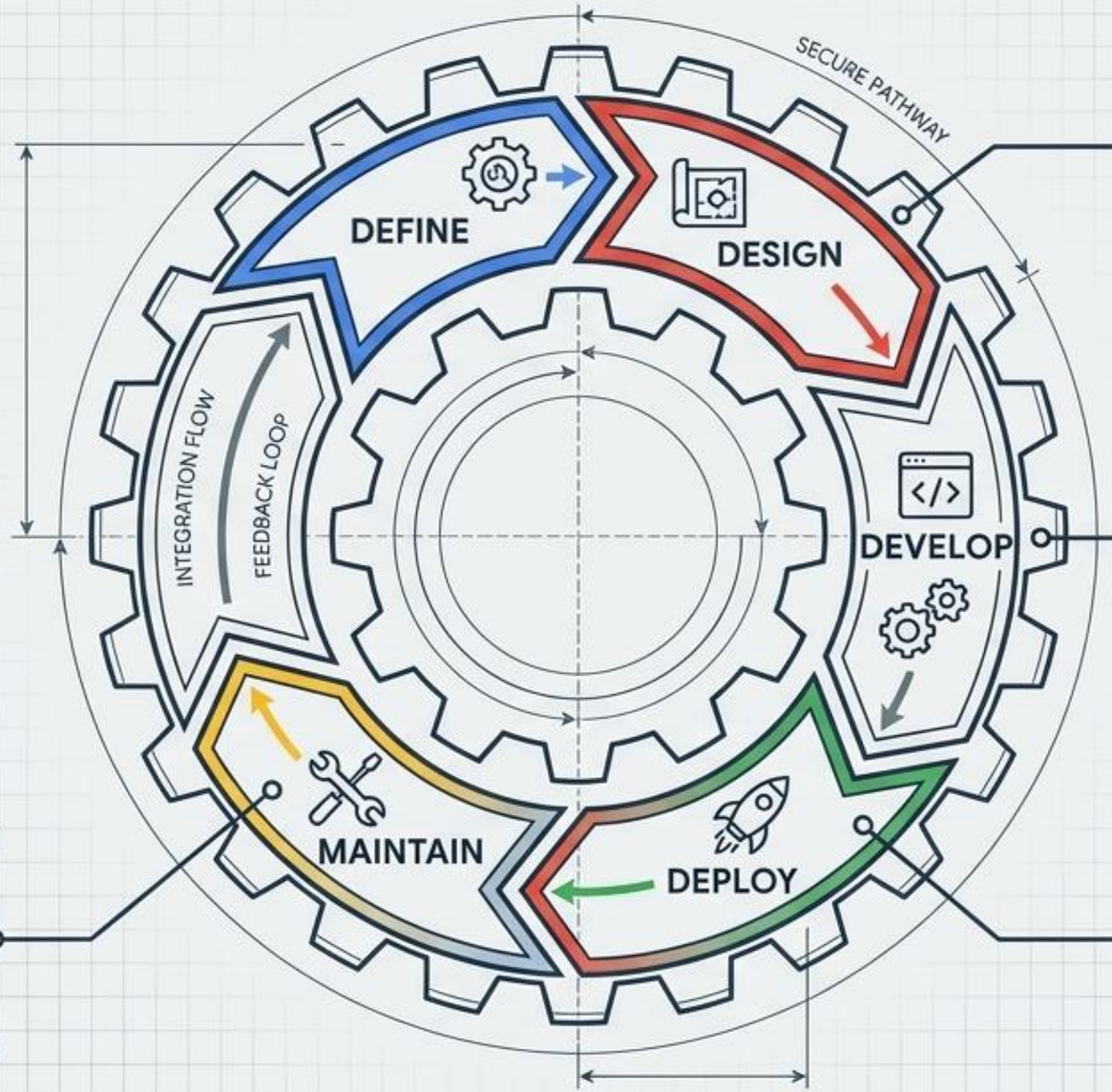
= ~$252,000/year

Hidden Savings			
	☐ Tracks token/inference cost reduction	☐ Avoided incidents	☐ Lower rework costs

Google Developer Groups
New Delhi

DevFest नई दिल्ली 2026

Integrating AI into the Secure SDLC



Threat modeling (Agent Agency), mapping data boundaries

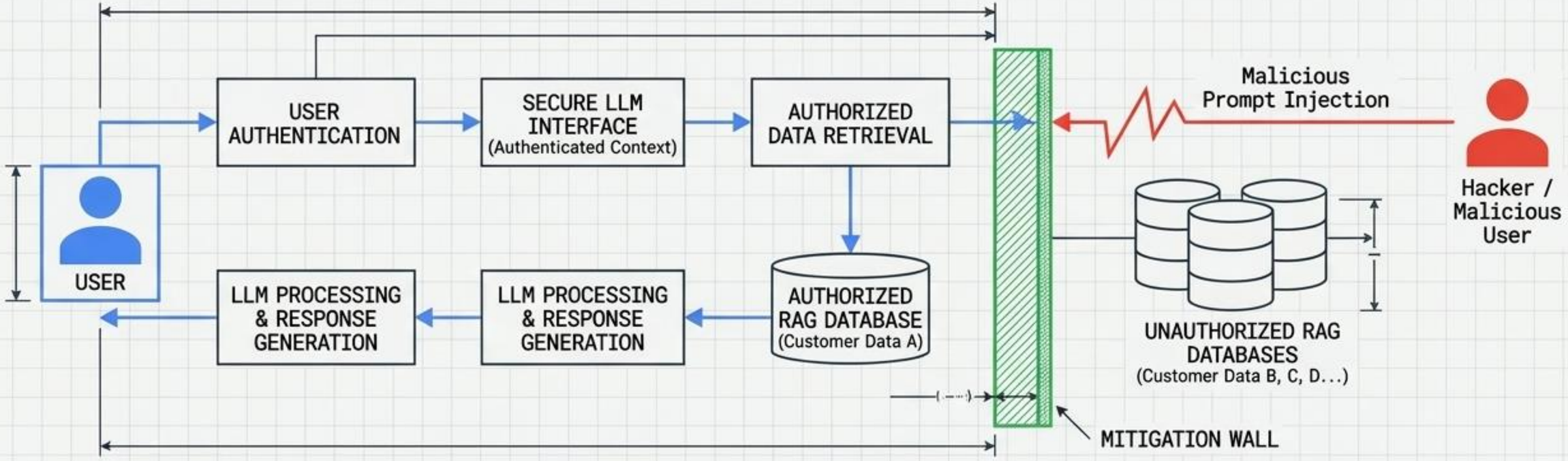
Evals creation, **static code reviews** for API integrations, **prompt injection fuzzing**

Guardrail regression testing, Red-teaming against the 5-layer stack

Continuous **trace observability**, drift monitoring

Gemini Notebook

Threat Modeling the AI Boundary (OWASP WSTG)



THE THREAT

Attacker uses Prompt Injection to harvest cross-customer data (WSTG AuthZ bypass equivalent).

THE MITIGATION

Hardcoded Access Control Lists (ACLs) at the Retrieval layer. The AI can only search data the authenticated user fundamentally owns.

TAKEAWAY: Treat LLM inputs identically to untrusted web inputs. Apply classic WSTG Input Validation and AuthZ methodologies.

Gemini Notebook

Operations: Test the Control, Not Just the Model



Adversarial

- Fuzzing for prompt injection
- Cross-customer access
- Tool abuse



Regression

- Testing against known-good and known-bad baselines after policy changes.



Quality

- Checking for grounding, unsupported claims, and false blocks.



Economics

- Monitoring latency, token usage, and manual review minutes.

TAKEAWAY: A control that cannot be continuously tested cannot be trusted at scale.

Gemini Notebook

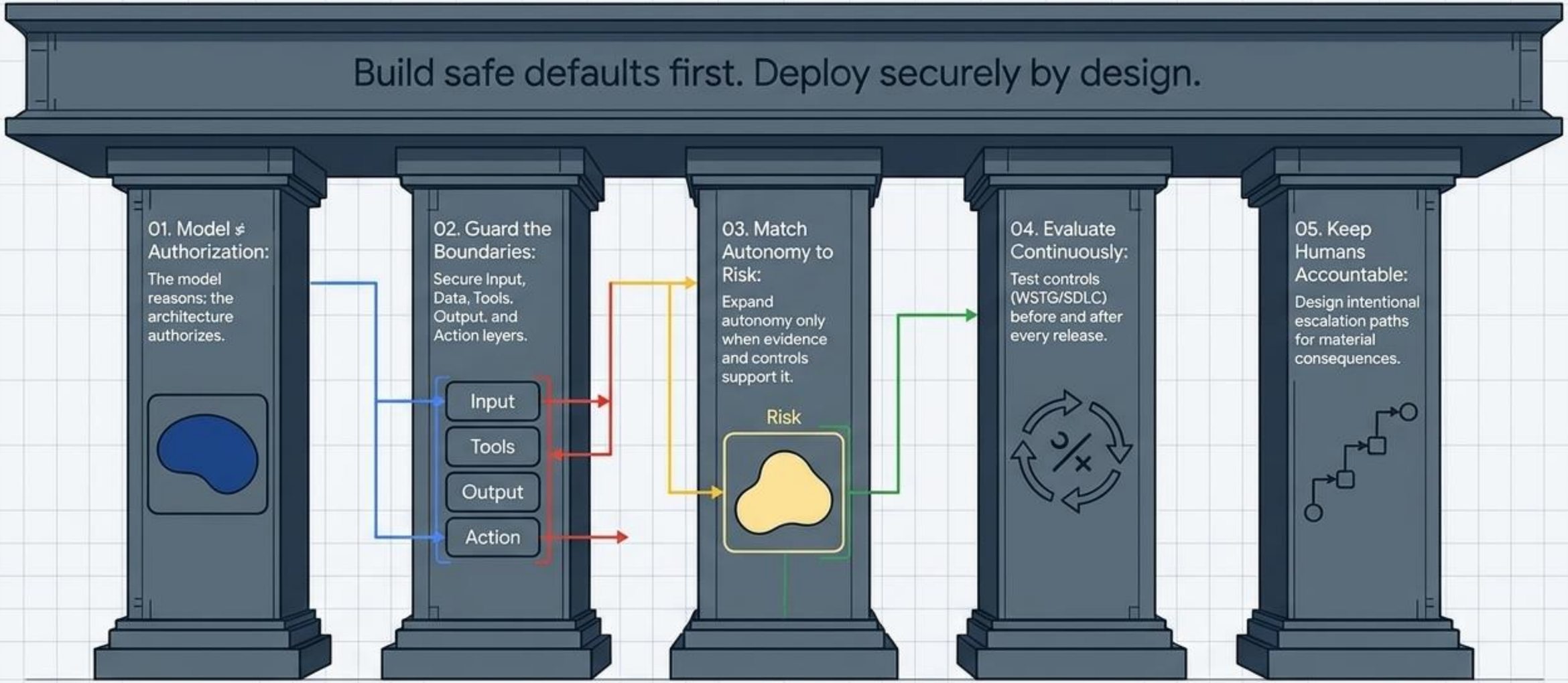
Human Oversight is a Feature, Not a Failure Mode



Trigger (Driven by Policy)	Context	Decide
High-impact actions, low confidence scores, or active fraud signals.	Human reviewer sees intent, AI output, and the explicit policy reason for escalation.	Approve, Edit, Reject, or Escalate.

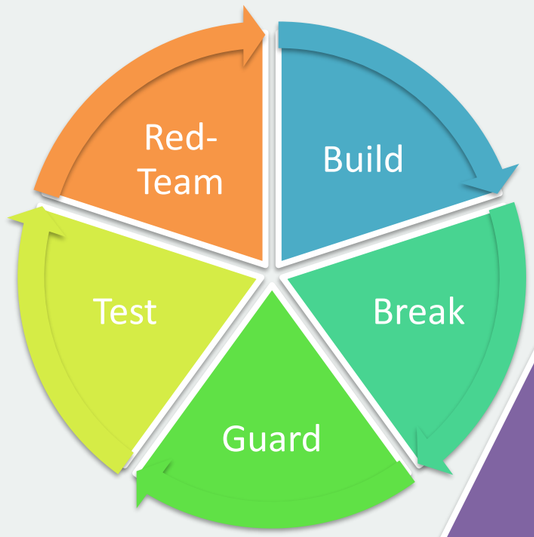
TAKEAWAY: Human review should be triggered programmatically by deterministic policy—never by system panic.

The Builder's Mandate: 5 Principles for Safe AI at Scale



Deterministic Laboratory

(Safe by Design)



- Mock Starter Pack
- Run App: python app.py
- Attack the App
- LLM Review Codebase
- Expose & Explore Vulnerabilities
- OWASP References
- Controls (Outside Cocoon of Model)
- Review
- Escalate
- Human Review + Red Team
- Transfer
- Deployment Signoff Approvals
- Summary: Humble Hearts & Brilliant Brains

Starter Kit:
https://github.com/ankitmathur111/lab_devfest2026_gdgnewdelhi/tree/main/Devfest2026_workshop_gdgNewDelhi/starter_kit/BankAssist-Kiro-Workshop-Starter

OWASP Quick Links:
https://owasp.org/projects/ai-testing-guide
https://owasp.org/projects/web-security-testing-guide

Google Developer Groups
New Delhi

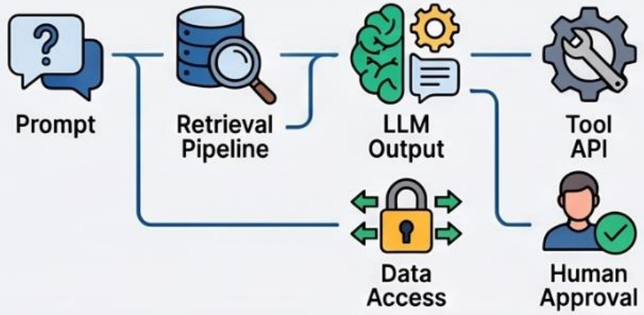
DevFest नई दिल्ली 2026

AI Banking Red Teaming & Security Control Guide

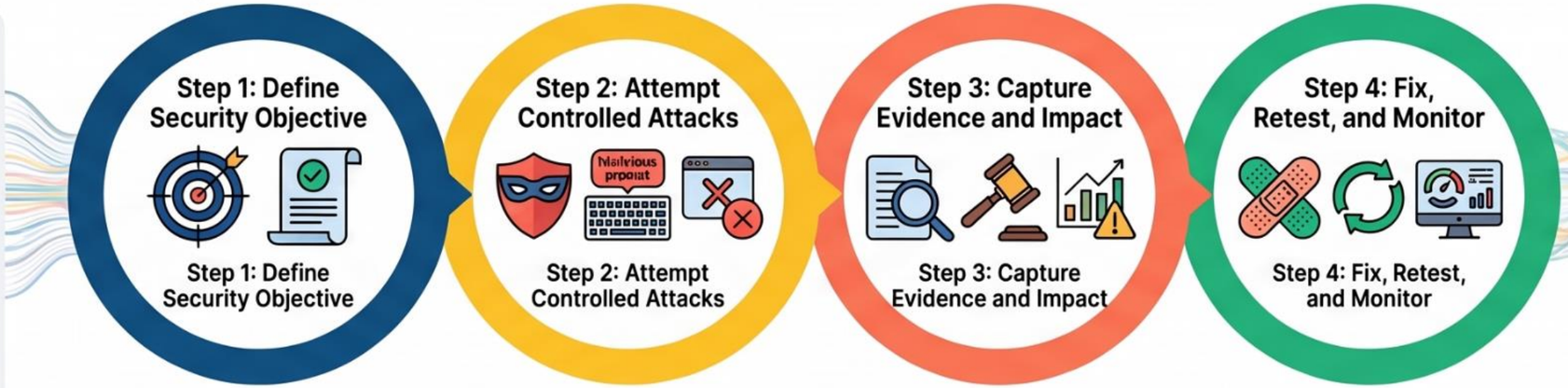
Deploying AI in banking shifts models to taking actions in core systems. Securing these systems requires evaluating not just the model, but the entire architecture—including prompts, retrieval pipelines, tool APIs, business rules, and human approval boundaries.

Section 1: Definition, Scope & The 4-Step Red-Team Cycle

Red Teaming Evaluates System Boundaries Across the Full AI Architecture



Tests inputs, prompts, retrieval pipelines, LLM outputs, tool APIs, data access, and human approvals.



Step 1: Define Security Objective

Establishes target policies, acceptable risk thresholds, and boundary conditions for the system.

Step 2: Attempt Controlled Attacks

Executes adversarial probes, including prompt injection, cross-customer data access, and tool misuse.

Step 3: Capture Evidence and Impact

Records traces, logs policy verdicts, and evaluates potential financial or operational consequences.

Step 4: Fix, Retest, and Monitor

Remediates flaws, runs continuous regression tests, and tracks live metrics.

Section 2: Security & Safety Testing Comparison Matrix

Differentiating Red Teaming from Traditional Security and Safety Evaluations

AI red teaming targets model and tool interaction risks rather than simple code bugs.

	Activity Category	Primary Focus & Method	Target Scope & Execution
1	**Vulnerability Assessment & Penetration Testing**	Automated scanning and manual exploitation of software flaws and network bugs	Infrastructure, servers, bespoke web applications, and access points
2	**AI Red Teaming & Safety Evaluations**	Adversarial attack simulation and benchmarking against grounded baselines	Prompts, RAG pipelines, LLM outputs, tool calls, and model compliance
3	**Security Control Testing**	Validating non-LLM deterministic rules, authorization gates, and human reviews	Boundary policies, identity/authz layers, tool limits, and audit trails

Google Developer Groups
New Delhi

DevFest नई दिल्ली 2026

Safe by Design: AI Security & Red Teaming for Banking Applications

Build. Test. Secure. Ensure AI delivers value — without compromising trust, data, or customers. **CVSS: Common Vulnerability Security System

What is Red Teaming?

Red teaming is an authorized, controlled exercise where testers deliberately try to make a system fail or violate its security requirements. For AI applications, it helps uncover weaknesses in the model, prompts, retrieval pipeline, tools, APIs, data access, business rules and human approval process.

AI Banking Red-Team Cycle

1. **Define the security objective**
   What must never happen? (e.g., one customer must never see another's account data).
2. **Attempt controlled attacks**
   Try prompt injection, unauthorized tool use, data leakage, and business-rule bypasses.
3. **Capture evidence and impact**
   Record the request, expected vs observed behavior, affected assets and reproducible evidence.
4. **Fix, retest and monitor**
   Implement controls, rerun the attack, verify normal use and retain evidence.

Red teaming is broader than penetration testing because AI can produce unexpected behavior from natural-language inputs and multi-component interactions.

Top 20 AI Security Highlights (Banking Focus)

1. Prompt injection
2. Sensitive information disclosure
3. AI supply-chain security
4. Data and model poisoning
5. Improper output handling
6. Excessive agency
7. System prompt leakage
8. Vector/embedding weaknesses
9. Misinformation & overreliance
10. Unbounded consumption
11. Agent goal hijacking
12. Tool misuse & exploitation
13. Identity & privilege abuse
14. Agentic supply-chain risks
15. Unexpected code execution
16. Memory & context poisoning
17. Inter-agent communication risks
18. Cascading failures
19. Human-agent trust exploitation
20. Rogue or misaligned behavior

These 20 highlights are derived from OWASP's current LLM and Agentic Application guidance and tailored for banking use cases.

20 Must-Have Security Controls for Banking AI

1. Identity, Access & Data Protection (1–5)

1. Strong authentication & session security
2. Server-side authorization on every operation
3. Least privilege for tools & service identities
4. Customer & tenant data isolation
5. Encryption & key management

2. Model, Prompt, Retrieval & Tool Controls (6–10)

6. Prompt-injection defenses
7. Input validation & content handling
8. Output validation & safe rendering
9. Permission-aware RAG & retrieval
10. Tool & API gateway enforcement

3. Transaction, Monitoring & Operational Controls (11–20)

11. Human approval for high-risk actions
12. Transaction integrity
13. Anti-replay & idempotency
14. Fraud & abuse detection
15. Audit trails
16. Runtime monitoring & alerting
17. Resilience & fail-safe behavior
18. Model, dependency & change governance
19. Security testing & release gates
20. Governance, privacy & incident response

10 Ways to Attack-Test the Application

1. **Direct prompt injection** – bypass rules or reveal data
2. **Indirect prompt injection** – via uploaded documents
3. **Cross-customer data access** – access another customer's data
4. **Sensitive data & prompt leakage** – expose secrets or PII
5. **Tool misuse / privilege escalation** – call unauthorized tools
6. **Transaction & approval bypass** – move money without approval
7. **Unsafe output handling** – trigger code or unsafe queries
8. **RAG or document poisoning** – inject false/malicious content
9. **Denial of service & cost abuse** – excessive requests or tokens
10. **Memory, identity & workflow abuse** – misuse context or identity

How to Analyse Severity of Results

Critical | High | Medium | Low

- **Assess impact** – confidentiality, integrity, availability, financial harm, regulatory impact, scope.
- **Evaluate exploitability** – access level, steps, reproducibility, control bypass.
- **Use CVSS for** applicable technical issues (with bank-specific context).
- **Record findings** – with evidence, remediation and retest status.

Recommended Export File Types

- PDF (Executive report)
- XLSX (Findings register)
- CSV (Import / GRC)
- JSON (Automation)
- SARIF (Code scanning)
- JUnit XML (Test results)
- HTML (Interactive report)
- TXT / MD (Notes / runbooks)



Critical Banking Workflow

The AI must propose.
The system decides.

1. **Customer request**
   Natural-language instruction
   "Transfer ₹50,000 to John for invoice #123."
2. **AI proposes a structured transfer**
   Amount · currency · beneficiary · source account
   ₹50,000 · INR · John Doe
   Savings **1234
3. **Trusted backend validates**
   Identity · account ownership · limits · fraud checks · policy
   Validation checks ✓
   Policy rules ✓
4. **Required approval and confirmation**
   Show exact details; require authenticated confirmation where policy requires it
   ✓ "Approve this transfer?"
5. **Transaction service executes**
   Only after authorization; record immutable or tamper-evident evidence
   Transaction complete
   Reference ID: TXN-987654

The AI must not be able to skip these stages by saying that a transfer is urgent, that the user has already approved it, or that a system prompt instructs it to bypass controls.

Starter Kit:

https://github.com/ankitmathur111/lab_devfest2026_gdgnewdelhi/tree/main/Devfest2026_workshop_gdgNewDelhi/starter_kit/BankAssist-Kiro-Workshop-Starter

Take Home Kit:

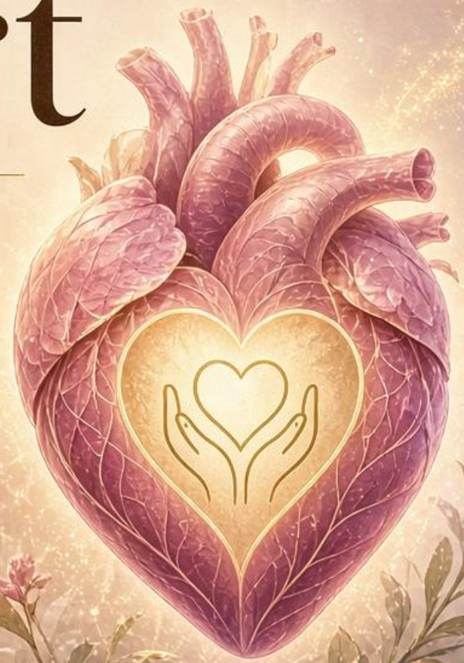
https://github.com/ankitmathur111/lab_devfest2026_gdgnewdelhi/tree/main/Devfest2026_workshop_gdgNewDelhi/takehome_kit/BankAssist-Kiro-Guardrails_basicExamples_working

Google Developer Groups
New Delhi

DevFest
नई दिल्ली 2026

Humble heart

GROUNDED IN KINDNESS.
GUIDED BY EMPATHY.



Brilliant Brain

POWERED BY CURIOSITY.
SHAPED BY WISDOM.



Grok

Google Developer Groups
New Delhi

DevFest
नई दिल्ली 2026

WE ARE *the FUTURE*

THANK YOU



Grok

Credits to LLMs:

- Gemini
- Notebook LM / Gemini LM
- ChatGPT
- Grok (Videos used in this session)
- Claude
- Inline credits provided for case studies, references, examples and all other materials of this session

Download PDF version of the presentation =>